Home Lab

1/Home lab :
a safe and isolated environment used to safely practice and test cybersecurity skills, tools and techniques without affecting or being affected by the real-world systems

typical components :
-virtualisation : virtual machines
-hypervisor
-security tools (wireshark, metasploit framework…)
-vulnerable machines for practice

Note : A hypervisor is software (or firmware) that creates, runs, and manages virtual machines by sharing the host computer's hardware resources among them.

2/SIEM :
-stands for security information and event management
-a security solution that collects events/logs from network, host devices, applications, security tools. it analyses and correlates them to detect suspicious activity and generate alerts based on configured rules.
-After collecting, normalizing, and correlating logs, the SIEM presents the data through dashboards, reports, and search interfaces to facilitate security monitoring and analysis

SIEM workflow :

Log Sources
|
▼
Collection
|
▼
Normalization
|
▼
Correlation
|
▼
Threat Detection
|
▼
Alert Generation

|
▼
Investigation & Response

Exemples : ELK, splunk

Main components :
- Log Sources
- Collectors/Agents
- Storage/Indexing
- Correlation Engine
- Threat Intelligence
- Alerting
- Dashboards & Reporting
- Search & Investigation

3/IOC :
-stands for indicator of compromise
-They are pieces of evidence that indicate a system has been compromised or that malicious activity has occurred
-they are collected from security tools, security solutions, logs or threat intelligence platforms
-They help security teams detect, investigate, contain, and respond to cyberattacks.

examples :
-network IOCs : malicious ip address, suspicious domain name, malicious URL, communication with command & control server…
-file IOCs : file hash, suspicious executable, malicious DLL (dynamic linker library), unexpected script
-host IOCs : suspicious running process, unknown windows service, new scheduled task, modified registry run key
-account IOCs : Multiple failed login attempts, logins at unusual times, login from an unexpected country
-email IOCs : phishing email, suspicious attachment, malicious macro-enabled Office document
-log IOCs : repeated authentication failures, unexpected privilege escalation, antivirus being disabled

4/IOA :
-stands for indicator of attack
-indicate that an attack is currently underway or about to occur
-focuses on the attacker’s behavior, techniques and intentions in real time rather than evidence of compromise.

-it helps organizations detect and stop the cyberattack before it causes damage
-IOAs are collected from security tools, endpoint agents, network monitoring tools, and behavioral analytics solutions that monitor suspicious activities in real time.

examples :
-credential-related IOAs : mulltiple failed logins attempts, password spraying, credential dumping
-execution IOAs

Note : Password spraying is a type of password attack in which an attacker tries one common password against many different user accounts, instead of trying many passwords against one account.

5/Containers :
-An isolated, lightweight runtime environment that contains an application and all the dependencies and libraries required to run it reliably across different environments
-An isolated runtime environment that runs on top of the host operating system. Containers share the same operating system kernel and many of the host OS services.
They virtualize the runtime environment by providing isolated namespaces, file systems, resource quotas, and other operating system features.

6/Docker :
-An open-source containerization platform used to build, manage, deploy, and run containers.
-**Docker image** a read-only template that contains an application and all the dependencies, libraries, and configuration files required to run it.
-Docker container : A Docker container is a running instance of a Docker image that executes the application in an isolated environment.

docker components :
- **Docker engine** :An execution environment consisting of the **Docker daemon**, **Docker API**, and **Docker CLI**, responsible for building, running, and managing Docker containers on a host machine.
- **docker image registry** : a server or repository used to store, manage, and distribute Docker images (users can pull from or push images to the registry)

Docker Hub : public repository of docker images

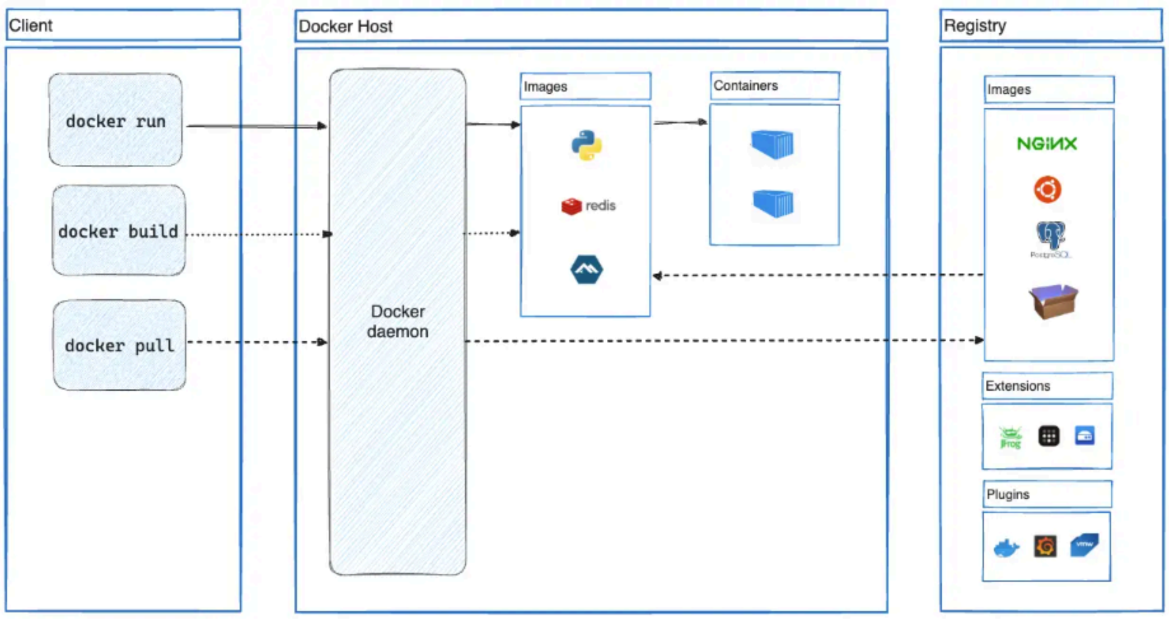
How does a docker works ?
1. **obtain the docker image** : build from your application using dockerfile or pull an existing one from image registry (such as docker hub)
2. **create a container** : the Docker engine creates and runs a container from the Docker image you have created

3. **Run the application** : once the container starts, the application executes inside the isolated container
4. **Deploy anywhere** : The same image can be deployed and run consistently on different systems (Windows, Linux, macOS) with Docker installed.

Note : the docker image is reused to recreate containers in other environments

Docker architecture :
Client-Server Architecture

- Server (Docker Daemon): Manages Docker images, containers, networks, and volumes on the host machine.
- Client (Docker CLI): A command-line interface that allows users to communicate with the Docker daemon by executing Docker commands.



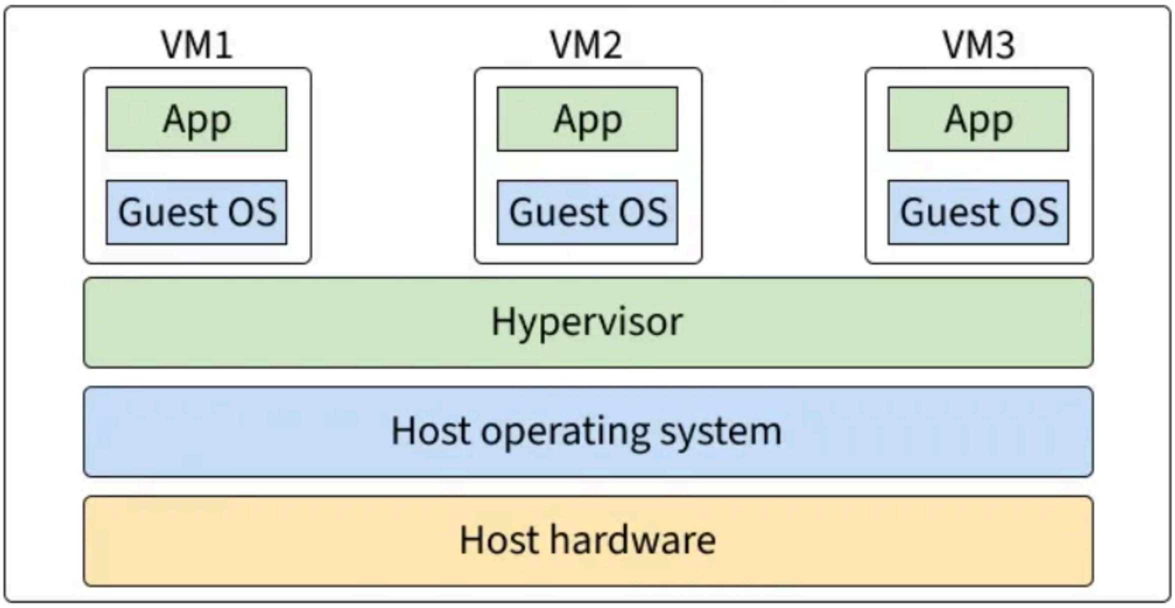
Note :
-the docker container shares the host operating system's kernel while using the host's real hardware resources (CPU, RAM, and disk).
-Docker provides isolation through OS-level virtualization, giving each container its own file system, processes, network, and environment.

7/Virtualization :
-is a technology that enables many virtual machines to run on a single physical computer by creating an abstraction layer over underlying hardware .

-This layer divides and allocates computer components such as the CPU, memory RAM, network interfaces and storage to multiple virtual machines
-a virtual machine is a software-defined computer that runs its own operating system and applications. It behaves like a separate physical computer despite sharing the host's hardware resources with other virtual machines

hypervisor :
-is software that creates, runs, and manages virtual machines by allocating the host computer's hardware resources (CPU, RAM, storage, and network) to each VM
-there are 2 types of hypervisor : hosted and bare-m

Architecture :



8/Comparaison virtualization and conteneurisation :
similarities :

- image : Both VMs and Docker containers are created from images. A VM image contains an operating system, while a Docker image contains an application and its dependencies.
- versioning : Both VM images and Docker images can be versioned to track configuration changes.
- portability : Both can be moved and deployed across different environments.
- Deployment : Both enable applications and services to be deployed consistently across development, testing, and production environments.

Differences :

	Virtualization	**Containerization**

Objective	create VMs	create containers
goal	Virtualize an entire computer.	Package and run an application. in many environments
OS	each vm has its own operating system and kernel	containers share the host OS's kernel
speed	heavier	lightweight
virtualization	virtualizes all the hardware	virtualizes the OS and the runtime environment
managed by	a hypervisor	docker engine
resource sharing	uses a fixed amount of resources defined in the virtual machine's configuration	shares resources on demand
Deployment	a VM can host an entire OS with multiple applications	a docker container is usually designed to run a single application or service

8/Difference XDR and SIEM :
XDR :
-extended detection and response
-Collect telemetry from multiple sources (endpoints, network, cloud, email, identity, etc.).
-Correlate and analyze the collected data.
-Detect threats.
-Respond to incidents automatically or manually.

Difference between SIEM and XDR

SIEM	XDR
Collects and correlates logs.	Collects and correlates telemetry from multiple security sources.
Mainly focuses on detection, monitoring, and investigation.	Focuses on detection and response.
Usually requires a SOC analyst to take action.	Can automate response actions (isolate, block, kill, quarantine, etc.).

Project docker components :
-Wazuh : is an open-source security platform that combines SIEM, XDR, and HIDS capabilities for endpoints and cloud workloads. It collects and analyzes security events from endpoints and other sources, detects threats, generates alerts, and supports automated incident response
Main components :

- **Wazuh Agent:** Collects logs, system information, and security events from monitored endpoints.
- **Wazuh Server (Manager):** Analyzes events, applies detection rules, correlates data, and generates alerts.
- **Wazuh Indexer:** Stores and indexes alerts for efficient searching and analysis.
- **Wazuh Dashboard:** Provides dashboards, visualizations, and management of the Wazuh platform.

how wazuh works ?
Wazuh works by :

- deploying lightweight agents on monitored systems (Windows, Linux, macOS, cloud instances, or containers).
- These agents collect security events such as logs, file integrity changes, vulnerabilities, and system information
- send them to the Wazuh Server.
- The server analyzes the data using detection rules and threat intelligence, generates alerts
- stores the results in the Wazuh Indexer
- displays them through the Wazuh Dashboard for security monitoring and incident response

-TheHive :
-An open-source Security Incident Response Platform (SIRP) used to centralize, manage, orchestrate, and automate security incident response
-Developed by StrangeBee, it is widely used by Security Operations Centers (SOCs) and Computer Emergency Response Teams (CERTs) to manage and investigate security incidents.
-they help security teams:

- Manage security alerts and incidents.
- Assign cases to analysts.
- Track the progress of investigations.
- Automate incident response workflows.
- Collaborate during investigations.
- Integrate with SIEM, XDR, EDR, and threat intelligence platforms.

Note: XDR focuses on technical response to stop or contain attacks, whereas TheHive focuses on incident management and orchestration by creating cases, assigning analysts, tracking investigations, and automating response workflows.

-Cortex : is an open-source analysis and response engine designed for SOCs, CSIRTs, and security researchers to automate threat intelligence gathering and incident response. Through its RESTful API, it allows teams to analyze observables at scale and automate response actions.

Observables : are pieces of information collected during an investigation that may be associated with malicious activity and can be analyzed to determine whether they are suspicious or malicious. they can be ip address, domain name, email address, file…
-observables can be legitimate or malicious, after analysis, if Cortex finds that this observable is malicious then it can be considered as an IOC

main features :
- efficient observable analysis : analyses observables, queries multiple threat intelligence sources, aggregates and centralizes the analysis result.
- automated threat response : executes automated response actions through responders, creates or updates incidents in platforms such as TheHive

<u>Responders</u> : are automated scripts or programs that perform predefined response actions to security incidents

-MISP :
-stands for malware information sharing platform
-is an **open-source Threat Intelligence Platform (TIP)** designed to collect, store, correlate, analyze, and share cyber threat intelligence.
-It enables organizations to exchange **Indicators of Compromise (IOCs)**, attack techniques, threat actors, malware information, and other threat intelligence to improve threat detection and incident response.

Main features :
- stores and shares IOCs
- shares Threat intelligence :
  -shares intelligence between organizations, CERTs, CSIRTs, SOCs, and security communities.
  -Helps organizations benefit from knowledge of previously observed attacks.
- Correlates observables and IOCs to identify relationships between incidents.
- organizes threat intelligence into **events**.
- integrates with many security platforms (SIEM, EDR, CORTEX…)

-Active Directory :

-A **Windows domain** is a centralized network environment in which objects such as **users, computers, groups, and resources** are centrally managed.
-Active Directory (AD) is Microsoft's **directory service** that stores information about domain objects and provides centralized **authentication, authorization, and access control** within a Windows domain.
-How does Active Directory work?
In every Windows domain, one or more **Domain Controllers (DCs)** host **Active Directory Domain Services (AD DS)**. The Domain Controller authenticates users, enforces Group Policies, manages domain objects, and provides directory services to computers and users within the domain.
-Active Directory Domain Services (AD DS) is the Windows Server role that implements Active Directory. It runs on a **Domain Controller** and is responsible for storing and managing the directory, authenticating users, authorizing access, and enforcing security policies.

```
Windows Domain
      |
      ▼
Domain Controller (Server)
      |
Runs
      ▼
Active Directory Domain Services (AD DS)
      |
Provides
      ▼
Active Directory
      |
Stores and manages
      ▼
Users, Computers, Groups, Policies, Resources...
```

-Tailscale :
-is a secure mesh VPN that connects devices into a private network using the WireGuard protocol, allowing secure remote access to devices and services from anywhere.
Note : Mesh VPN: A VPN architecture in which devices establish direct encrypted peer-to-peer connections instead of routing all traffic through a central VPN server.

Why use Tailscale? To securely access computers, servers, virtual machines, and services remotely as if they were on the same local network.

Why Tailscale instead of a traditional VPN?

With a traditional VPN, you typically need to:

- Install and maintain a VPN server.
- Configure port forwarding.
- Open firewall ports.
- Configure certificates.
- Manage VPN users and server settings.

Tailscale simplifies this process.

Instead of setting up and managing a VPN server:

- you install Tailscale on each device and sign in with the same account (or an authorized account).
- Tailscale automatically creates a secure private virtual network called a Tailnet.
- Each device receives a private Tailscale IP address, allowing all authorized devices to communicate securely from anywhere over the Internet.

Note : Tailnet: A private, encrypted virtual network created by Tailscale that connects all authorized devices as if they were on the same local network.

How is the communication secure?

- Tailscale uses the WireGuard protocol to establish end-to-end encrypted connections between devices.
- Whenever possible, devices communicate directly (peer-to-peer) without routing data through a central VPN server.

-Linux server :

A computer running a Linux operating system (e.g., Ubuntu) that provides services and resources over a network. In a cybersecurity home lab, it is commonly used to host security tools and applications such as Wazuh, TheHive, Docker, or web servers, and can be monitored by a Wazuh agent for security monitoring and log collection.

.

Composant	Rôle	Image Docker

Wazuh	SIEM / XDR — collecte et corrélation d'alertes	`wazuh/wazuh-manager:4.7.x`
TheHive	Gestion des incidents et cas de sécurité	`strangebee/thehive:5`
Cortex	Analyse automatisée d'observables	`thehiveproject/cortex:3`
MISP	Plateforme de threat intelligence et IOC	`coolacid/misp-docker:latest`
Active Directory	Annuaire Windows, source de logs Sysmon	`dockurr/windows:latest` (AD DS)
Linux Server	Serveur Ubuntu supervisé par agent Wazuh	`ubuntu:22.04` + agent Wazuh
Tailscale	VPN mesh WireGuard reliant tous les conteneurs	`tailscale/tailscale:latest`